

SIMATS ENGINEERING

ASSESSMENT TOOL 2

Name	Abinеш M
Register Number	192465050
Date	
Time	1 Hr

COURSE NAME: **Cybersecurity Incident Handling And Response**

COURSE CODE: **CSA6001**

COURSE OUTCOME COVERED

CO3: *Assess incident identification processes using monitoring systems, log analysis, threat intelligence, detection mechanisms to verify incidents, classify threats, assess their impact.*
(BL2, BL3)

Activity Tool : IOC Identification and Threat Hunting Analysis (Medium)

Assessment Tool Weightage: 20%

Code of Conduct:

*I Abinеш M 192465050 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student:

Abinеш M
192465050

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
IOC Identification and Analysis	25%	Accurately identifies and thoroughly analyzes relevant IOCs such as IP addresses, domains, URLs, file hashes, suspicious processes, and abnormal activities, with clear justification.	Identifies and analyzes most relevant IOCs with minor omissions or limited justification.	Identifies some IOCs but provides limited or incomplete analysis.	Unable to identify relevant IOCs or explain their significance.
Threat Hunting Methodology	25%	Develops a systematic threat-hunting approach using hypotheses, data collection, searching, analysis, investigation, and appropriate response actions.	Applies a suitable threat-hunting process with minor gaps in methodology or sequencing.	Demonstrates basic threat-hunting activities but lacks a systematic approach.	Unable to demonstrate an appropriate threat-hunting methodology.
Use of Security Data and Correlation	20%	Effectively uses and correlates SIEM, EDR, IDS/IPS, network, host, authentication, and application data to identify hidden or suspicious activities.	Uses multiple security data sources and performs reasonable correlation with minor gaps.	Uses limited data sources with incomplete correlation.	Fails to use relevant security data or establish meaningful correlations.
Threat Intelligence, Anomaly and Behavioural Analysis	15%	Effectively integrates threat intelligence, anomaly detection, and behavioural analysis to identify sophisticated, unknown, or evolving threats.	Uses threat intelligence and behavioural/anomaly analysis appropriately with minor omissions.	Demonstrates limited understanding or application of these techniques.	Unable to apply threat intelligence, anomaly detection, or behavioural analysis effectively.
Investigation, Documentation, and Presentation	15%	Presents a clear, professional investigation with evidence, findings, attack sequence, conclusions, and appropriate recommendations supported by diagrams or workflows.	Provides well-organized documentation and reasonable findings with minor presentation or analytical issues.	Documentation is partially organized with limited evidence, analysis, or conclusions.	Documentation is incomplete, poorly organized, and lacks supporting evidence or meaningful conclusions.

IOC Identification, Threat Hunting, and Malware Investigation

Question 1: IOC Identification and Threat Hunting

Unusual login attempts, suspicious IP connections, and unexpected process execution together suggest a potential intrusion involving initial access, possible lateral movement, and command-and-control (C2) activity. As a threat hunter, my objective is not simply to react to the alerts already raised, but to proactively use the available Indicators of Compromise (IOCs) as a starting point for a structured hunt across the environment to confirm scope, uncover related activity the alerting tools may have missed, and validate whether a genuine compromise has occurred.

1. Identifying Relevant IOCs

- **Host-based indicators** — unfamiliar or newly created user accounts, unexpected scheduled tasks or services, unusual parent-child process relationships (e.g., Office applications spawning PowerShell), and unsigned or renamed executables running from atypical directories.
- **Network-based indicators** — connections to IP addresses or domains with poor reputation or no prior organizational history, beaconing at regular intervals, use of uncommon ports/protocols, and DNS requests for algorithmically generated domain names (DGA-style).
- **Account/identity indicators** — repeated failed logins followed by success (credential stuffing/brute force), logins from atypical geographies or impossible-travel patterns, and authentication outside normal business hours or from unmanaged devices.
- **Artifact-based indicators** — file hashes (MD5/SHA-256) of suspicious binaries, registry-key modifications associated with persistence, and command-line arguments consistent with reconnaissance or credential-dumping tools.

Each IOC is enriched against threat-intelligence sources (VirusTotal, AbuseIPDB, MISP, commercial feeds) and mapped to known attacker tactics using the MITRE ATT&CK framework, which turns a raw indicator into context about what stage of an intrusion it likely represents.

2. Conducting a Systematic Threat Hunt

- **Step 1 — Formulate a hypothesis:** Based on the initial indicators (e.g., 'a phishing-derived credential was used to gain remote access and execute a reconnaissance tool'), define a specific, testable hypothesis rather than searching without direction.
- **Step 2 — Scope the hunt:** Identify which hosts, accounts, and network segments are in scope based on where the initial IOCs were observed, then expand outward to systems that communicate with them.
- **Step 3 — Pivot on IOCs across the environment:** Search the SIEM/EDR for the same source IPs, file hashes, or account names across all hosts and time ranges — not just where they were originally flagged — to find related activity the automated alerts missed.

- **Step 4 — Look for TTPs, not just IOCs:** Since IOCs like IPs and hashes are easily changed by attackers, also hunt for the underlying tactics, techniques, and procedures (TTPs) — such as a specific process-injection technique or lateral-movement method — which are far harder for an attacker to disguise.
- **Step 5 — Validate and eliminate false positives:** Confirm findings against legitimate business activity (scheduled maintenance, known admin tools) before escalating, since threat hunting produces leads, not automatic conclusions.
- **Step 6 — Document and escalate:** Record every pivot, query, and finding for reproducibility; if compromise is confirmed, hand off a scoped list of affected hosts/accounts to the incident response team for containment.

3. Outcome of the Hunt

A successful hunt produces one of three outcomes: confirmation of a compromise with a defined scope (which hosts, accounts, and data were affected), a disproven hypothesis with documented evidence for why the activity is benign, or a partially confirmed hypothesis that refines detection rules and feeds new IOCs back into monitoring tools for the future — ensuring the organization gets lasting value from the hunt regardless of the immediate outcome.

4. Tools and Data Sources Used in the Hunt

- **SIEM platform (Splunk, QRadar, Microsoft Sentinel, Elastic):** central query engine for pivoting on IOCs across all log sources and time ranges.
- **EDR/XDR tooling (CrowdStrike, Defender for Endpoint, SentinelOne):** provides process trees, command-line history, and the ability to isolate a host mid-hunt.
- **Network detection tools (Zeek, Suricata, NetFlow analyzers):** surfaces connection metadata and protocol anomalies without needing full packet capture.
- **Threat-intelligence platforms (MISP, VirusTotal, AbuseIPDB, commercial feeds):** enriches raw IOCs with reputation data and links them to known campaigns or malware families.
- **MITRE ATT&CK Navigator:** maps observed behaviors to known tactics and techniques, highlighting coverage gaps and suggesting where else to hunt.

5. Example IOC-to-ATT&CK Mapping

Mapping raw indicators to the ATT&CK framework helps prioritize which parts of the environment to hunt next, since a single technique is often reused across multiple stages of an intrusion.

Observed IOC	Likely ATT&CK Technique	Hunting Follow-Up
Repeated failed logins, then success	T1110 – Brute Force	Check for the same source IP hitting other accounts across the domain
Office app spawning PowerShell	T1059 – Command and Scripting Interpreter	Pull full command-line arguments and check for encoded/obfuscated payloads

Observed IOC	Likely ATT&CK Technique	Hunting Follow-Up
Regular-interval outbound connections	T1071 – Application Layer Protocol (C2)	Search all hosts for connections to the same destination or ASN
New scheduled task or service	T1053 / T1543 – Persistence	Enumerate all scheduled tasks/services created in the same time window domain-wide

Question 2: IOC-Based Malware Investigation

Multiple employees reporting unusual system behavior, combined with unknown files, suspicious processes, unusual outbound connections, and abnormal file hashes, points toward a possible malware outbreak — potentially a worm, trojan, or commodity malware spreading across the environment. As the responding analyst, my process is to identify each IOC, independently validate that it is genuinely malicious rather than a false positive, and then correlate the indicators together to establish whether this constitutes a confirmed malware incident and, if so, its scope.

1. Identifying the IOCs

IOC Type	What to Collect	Initial Triage Action
Unknown files	File path, name, creation timestamp, digital signature status	Isolate a copy; do not execute on production systems
Suspicious processes	Process name, parent process, command-line arguments, loaded modules	Capture via EDR/Sysmon before termination for forensic value
Outbound connections	Destination IP/domain, port, protocol, frequency, data volume	Check against threat-intel feeds and known C2 infrastructure lists
File hashes	MD5/SHA-1/SHA-256 of suspicious binaries	Submit to VirusTotal / sandbox for reputation and behavior analysis

2. Validating the IOCs

- **Static analysis:** Examine unknown files' metadata, digital signature, packing/obfuscation indicators, and compare file hashes against reputation databases and known malware-family hash sets.
- **Dynamic analysis:** Detonate suspicious files in an isolated sandbox to observe actual behavior — what files it creates, what registry keys it modifies, and what network connections it initiates — confirming intent rather than relying on static signatures alone.
- **Process legitimacy check:** Verify whether flagged processes are signed, running from expected install paths, and match known-good baselines for that system; unsigned processes running from temp or user-profile directories are high-suspicion.

- **Network validation:** Confirm outbound destinations against threat-intelligence feeds and check whether the connection pattern (timing, volume, persistence) is consistent with beaconing rather than legitimate application traffic.
- **False-positive filtering:** Cross-check findings against IT-approved software, recent patches, or known administrative tools to avoid chasing benign anomalies.

3. Correlating the IOCs

Individually, an unknown file, an odd process, or a single outbound connection could each have an innocent explanation. Correlation is what converts isolated observations into a confirmed malware determination:

- Link the unknown file's hash to the suspicious process that executed it, establishing that the file is not just present but active.
- Link the suspicious process to the outbound connection, confirming the process is communicating externally (consistent with C2 or exfiltration behavior).
- Compare affected employees' systems for common IOCs (same file hash, same destination IP, same process name) to determine whether this is a single infection or a spreading outbreak.
- Build a timeline across affected hosts to identify patient zero and the likely propagation method (email attachment, removable media, network share, exploited service).
- Map the combined behavior to a known malware family or MITRE ATT&CK technique set to inform the appropriate remediation approach.

4. Determining Whether Malware Is Present

- **Confirmed malware** — Sandbox detonation shows malicious behavior, the file hash matches known malware or exhibits clear malicious activity, and correlated process/network evidence shows active execution and external communication across one or more hosts. This triggers isolation of affected endpoints, credential resets, and organization-wide IOC blocking.
- **Likely false positive** — The file is unsigned but benign (e.g., an internal tool), the process is confirmed as approved software, and outbound connections resolve to legitimate services. Findings are documented, and detection rules are tuned to reduce future noise.
- **Requires deeper investigation** — Evidence is mixed or the sandbox is inconclusive (e.g., the malware detects the sandbox and withholds its payload). The response is to escalate for manual reverse engineering and to place affected hosts under enhanced monitoring while the investigation continues.

Throughout the investigation, all validated IOCs — hashes, IPs, domains, and behavioral indicators — are documented and distributed to detection tooling (EDR, firewall, email gateway) so the same threat cannot re-enter through the same vector, and the incident record is preserved for post-incident review.

5. Containment and Remediation Once Malware Is Confirmed

- **Immediate containment:** Isolate affected endpoints from the network (via EDR network-isolation or VLAN quarantine) to stop further spread and outbound communication while preserving the system for forensic capture.
- **Credential hygiene:** Reset credentials for any accounts active on infected hosts, since malware with keylogging or credential-dumping capability may have already harvested them.
- **Eradication:** Remove the malicious files, persistence mechanisms (scheduled tasks, registry run keys, services), and any dropped secondary payloads identified during dynamic analysis, then rebuild from a known-good image if integrity cannot be fully confirmed.
- **Indicator distribution:** Push validated hashes, IPs, and domains to EDR, firewall, and email-gateway block lists organization-wide so the same malware cannot re-enter through the same vector.
- **Verification:** Re-scan and monitor previously affected hosts for a defined period to confirm the infection does not reappear before returning them to normal production use.
- **Post-incident review:** Document the initial infection vector, timeline, and response actions, and use the findings to close the gap that allowed initial entry (e.g., email filtering rules, patching, user awareness training).

Conclusion

Both scenarios reinforce the same core discipline: IOCs are the starting point of an investigation, not the conclusion. Whether hunting proactively for signs of unauthorized access or responding reactively to reports of malware, the analyst's job is to identify indicators from multiple sources, validate each one independently to rule out false positives, and correlate them into a coherent picture of attacker activity and scope. This evidence-based approach — combined with mapping findings to known attacker techniques and feeding confirmed IOCs back into detection tooling — is what allows a security team to move from isolated alerts to a confident, well-scoped incident response.

Comparing the Two Approaches

Aspect	Threat Hunting (Question 1)	Malware Investigation (Question 2)
Trigger	Proactive — analyst-driven hypothesis based on early indicators	Reactive — driven by user reports and security-tool alerts
Primary focus	Uncovering unknown or missed attacker activity across the environment	Confirming and scoping a specific suspected malware infection
Core technique	Hypothesis-driven pivoting on IOCs and TTPs across hosts	Static and dynamic (sandbox) analysis of specific artifacts

Aspect	Threat Hunting (Question 1)	Malware Investigation (Question 2)
Typical output	Confirmed/disproven hypothesis; new detection rules	Confirmed/ruled-out malware determination; remediation plan

In practice, these two disciplines feed each other: a confirmed malware investigation often produces new IOCs and TTPs that seed the next round of threat hunting, and a threat hunt that uncovers unfamiliar artifacts frequently transitions directly into a malware investigation. Maintaining both capabilities — and the shared documentation, tooling, and threat-intelligence pipeline behind them — gives an organization a continuous feedback loop between proactive detection and reactive response.